

# Autenticação de API

Tokens, OAuth 2.0, JWT e controles de acesso em APIs.

## Autenticação × autorização

Autenticação comprova identidade; autorização determina o que aquela identidade pode acessar.

## OAuth 2.0 e tokens

Em APIs modernas, tokens de acesso são comuns. QA deve validar token ausente, inválido, expirado, escopos incorretos e renovação quando aplicável.

## JWT

JWT é um formato de token. Valide assinatura, expiração, claims e comportamento da API; nunca trate apenas a decodificação do payload como prova de validade.

## Quando usar

Use este conhecimento quando o risco, a arquitetura ou a etapa do ciclo de desenvolvimento exigir validação específica. Antes de aplicar, confirme objetivo, ambiente, dados necessários e evidências esperadas.

## Como o QA aplica na prática

Comece pelo comportamento ou risco que precisa ser validado, prepare dados e ambiente, execute a técnica ou ferramenta de forma reproduzível e registre evidências que permitam explicar o resultado ao time.

## Boas práticas

Priorize cenários de maior impacto, mantenha dados e ambiente controlados, registre decisões importantes e revise periodicamente a abordagem para evitar cobertura redundante ou desatualizada.

## Dica de QA

Relacione sempre a prática ao risco do produto e às evidências necessárias para a decisão de qualidade.

## Recursos oficiais

Site oficial: <https://datatracker.ietf.org/doc/html/rfc6749>